

Manual 26 — Implementación Controlada de Respuesta a Incidentes y Gestión de Crisis Cibernéticas

Traducción de proyecto es-419 — no oficial.

Base de fuentes: NIST SP 800-61 Rev. 3 (final, abril de 2025) sustituye a Rev. 2 y alinea la respuesta a incidentes con CSF 2.0. La orientación de CISA y las reglas de notificación específicas por jurisdicción son fuentes de apoyo o superpuestas y no deben tratarse como universalmente vinculantes. Revalide el estado vigente de las fuentes antes de publicar.

01. Propósito, alcance y límite de aseguramiento

Defina un modelo práctico de operación para respuesta a incidentes y crisis cibernéticas sin implicar suficiencia jurídica universal, reportabilidad de brechas u opinión de auditoría.

02. Jerarquía de fuentes y control de versiones

Separe orientación de NIST, orientación de CISA, reglas regulatorias de notificación, obligaciones contractuales, capas sectoriales, requisitos de aseguradoras y políticas internas.

03. Gobernanza y rendición de cuentas ejecutiva

Asigne patrocinador ejecutivo, comandante del incidente, líder de crisis, roles jurídicos y de privacidad, autoridad de comunicaciones, responsables del negocio y responsabilidad sobre evidencia.

04. Política de respuesta a incidentes

Defina alcance, autoridad, umbrales de severidad, escalamiento, evidencia, comunicaciones, recuperación, lecciones aprendidas y requisitos de gobernanza.

05. Preparación organizacional

Mantenga preparación de personas, procesos, herramientas, registros, datos de contacto, accesos, respaldos, capacidad forense, proveedores y soporte para decisiones.

06. Contexto de activos, servicios y dependencias

Vincule la respuesta a incidentes con servicios críticos, activos, identidades, aplicaciones, servicios en nube, proveedores, instalaciones y procesos de negocio.

07. Planificación de amenazas y escenarios

Mantenga bibliotecas de escenarios para ransomware, robo de datos, compromiso de cuentas, abuso de nube, eventos de cadena de suministro, malware destructivo, uso indebido interno e interrupción de servicios.

08. Detección e ingreso de eventos

Defina fuentes monitoreadas, triage de alertas, reporte por usuarios/proveedores, canales de escalamiento, datos mínimos de ingreso y preservación de evidencia.

09. Triage y análisis inicial

Evalúe credibilidad, alcance, servicios afectados, indicadores, impacto probable, incertidumbre y necesidades inmediatas de contención.

10. Declaración y severidad del incidente

Use criterios documentados de declaración y niveles de severidad vinculados con impacto, propagación, disparadores jurídicos/regulatorios, daño a clientes, seguridad física y atención ejecutiva.

11. Estructura de mando del incidente

Defina mando operativo, frentes especializados, autoridad de decisión, transferencias, ritmo operativo y requisitos del registro de mando.

12. Integración con gestión de crisis

Escale desde manejo de incidentes hacia gobernanza de crisis empresarial cuando se alcancen umbrales de negocio, jurídicos, seguridad, reputación, geopolítica o ejecutivos.

13. Investigación y preservación de evidencia

Preserve registros, imágenes, artefactos, cronologías, registros de cadena de custodia, notas de analistas y evidencia de decisiones de forma proporcional a necesidades jurídicas y operativas.

14. Estrategia de contención

Seleccione acciones de contención de corto y largo plazo según impacto, persistencia del atacante, criticidad del negocio, seguridad, daño a clientes y restricciones de recuperación.

15. Erradicación y análisis de causa raíz

Elimine presencia maliciosa, corrija debilidades explotadas, invalide credenciales comprometidas, remueva persistencia y documente factores causales.

16. Planificación de recuperación

Defina orden de restauración, criterios de estado limpio, validación de seguridad, aceptación del responsable del negocio, monitoreo, reversión y decisiones sobre riesgo residual.

17. Recuperación de identidad y acceso

Aborde restablecimiento de credenciales, revocación de tokens, acceso privilegiado, controles de emergencia, federación, cuentas de servicio y compromiso del proveedor de identidad.

18. Respuesta a ransomware y extorsión

Defina gobernanza de decisiones para cifrado, robo de datos, extorsión, fuerzas del orden, aseguradora, asuntos jurídicos, comunicaciones, restauración y revisión relacionada con sanciones, sin prescribir decisiones de pago.

19. Coordinación de brechas de datos e incidentes de privacidad

Coordine privacidad, asuntos jurídicos, seguridad, registros, clientes, reguladores y evaluación por jurisdicción, preservando pruebas diferenciadas de reportabilidad.

20. Notificación regulatoria y contractual

Mantenga una matriz de notificación consciente de jurisdicciones y obligaciones con campos de disparador, plazo, autoridad, responsable, contenido, evidencia y control de cambios.

21. Incidentes de terceros y cadena de suministro

Defina notificación de proveedores, evidencia, coordinación de contención, servicio alternativo, escalamiento contractual, aseguramiento y respuesta a riesgo de concentración.

22. Incidentes en nube y SaaS

Aborde responsabilidad compartida, registros del proveedor, aislamiento del tenant, identidad, abuso de API, impactos regionales, acceso a evidencia, escalamiento al proveedor y dependencias de recuperación.

23. Incidentes OT/ICS y sensibles a la seguridad

Preserve seguridad, confiabilidad, autoridad de ingeniería, restricciones del proceso, evidencia, coordinación con proveedores y escalamiento sectorial por encima de acciones puramente centradas en TI.

24. Comunicaciones y gestión de partes interesadas

Defina comunicaciones internas, avisos a clientes, respuesta a medios, autoridad del portavoz, aprobación de mensajes, control de rumores e informes ejecutivos.

25. Registro de decisiones y expedientes de crisis

Mantenga decisiones con sello de tiempo, supuestos, evidencia considerada, aprobadores, alternativas, riesgos residuales y acciones de seguimiento.

26. Privilegio jurídico y límites de investigación

Coordine decisiones lideradas por asesoría jurídica cuando corresponda sin asumir que el privilegio aplica automáticamente; separe hechos operativos de conclusiones jurídicas.

27. Integración con continuidad del negocio y recuperación ante desastres

Vincule respuesta a incidentes con activación del SGContinuidad, recuperación ante desastres, operaciones alternas, continuidad de proveedores y umbrales de gestión de crisis.

28. Ejercicios y simulaciones

Ejecute ejercicios de mesa, técnicos, ejecutivos, con proveedores, ransomware, nube, comunicaciones y crisis integradas con objetivos medibles.

29. Métricas y gestión del desempeño

Mida detección, declaración, contención, erradicación, recuperación, recurrencia, hallazgos de ejercicios, preparación para notificación, antigüedad de problemas e integridad de evidencia.

30. Revisión posterior al incidente y remediación

Realice lecciones aprendidas, validación de causa raíz, análisis de brechas de control, seguimiento de acciones, aceptación de riesgo residual y verificación de cierre.

31. Aseguramiento y revisión por la dirección

Proporcione revisión independiente y supervisión de liderazgo sobre preparación, incidentes, ejercicios, métricas, hallazgos, recursos y prioridades de mejora.

32. Publicación, evidencia y hoja de ruta de implementación

Empaquete rutas de implementación Esencial / Estructurada / Mejorada con verificación de fuentes, localización, accesibilidad, procedencia, checksums, seguridad de workflows, identidad exacta del candidato y controles de publicación secuencial.